

Post-Quantum Privacy-Preserving Cryptography for Healthcare: Proxy Re-Encryption, Homomorphic Vital Signs Analytics, and Verifiable Credentials for Electronic Health Records

Prabakaran Kannan

Research Scholar, Department of Computer Science and Engineering

National Institute of Technology Puducherry

Email: cs23d2005@nitpy.ac.in

Abstract—The healthcare sector faces a dual challenge: protecting sensitive patient data under stringent regulations such as HIPAA and GDPR while preparing for the cryptographic disruption posed by large-scale quantum computers. Current electronic health record (EHR) systems rely on RSA and elliptic-curve primitives that Shor’s algorithm will render insecure, exposing decades of archived patient records to harvest-now-decrypt-later attacks. This paper presents four complementary post-quantum cryptographic constructions tailored to the healthcare domain. First, we introduce a *lattice-based proxy re-encryption (PRE)* scheme for EHR transfer built on **ML-KEM-768 (FIPS 203)**, enabling a semi-trusted proxy to transform ciphertext between providers without accessing plaintext. The re-encryption key is derived as $rk = \text{SHAKE256}(sk_A || pk_B || pid)$ and supports six consent types—full access, category-restricted, time-limited, emergency, research, and one-time—covering standard and restricted record categories including mental health (42 CFR Part 2), genetic data (GINA), and reproductive health. Second, we present a *Paillier-like additively homomorphic encryption* scheme under lattice assumptions for privacy-preserving vital signs analytics, supporting encrypted summation $\text{Enc}(m_1) \cdot \text{Enc}(m_2) = \text{Enc}(m_1 + m_2)$, scalar multiplication $\text{Enc}(m)^k = \text{Enc}(k \cdot m)$, and integrated Laplace-mechanism differential privacy with $\epsilon = 1.0$. Seven vital types—heart rate, systolic and diastolic blood pressure, SpO_2 , temperature, respiratory rate, and glucose—are encrypted at the device with a scale factor of 100 for fixed-point representation. Third, we design *post-quantum verifiable credentials* conforming to the W3C VC 2.0 data model, signed with **ML-DSA-65 (FIPS 204)** and featuring Merkle-tree selective disclosure, zero-knowledge predicate proofs, and accumulator-based $O(1)$ revocation. Seven credential types—vaccination, lab result, prescription, allergy, insurance eligibility, disability attestation, and provider license—are supported with a default 365-day validity. Fourth, we propose a *lightweight PQC framework* for constrained medical devices, defining four memory tiers from ultra-constrained (<32 KB) to standard (>256 KB) with device-specific profiles for pacemakers, insulin pumps, and implantable cardioverter defibrillators. Strategies include pre-computation of key material during device programming, session key caching, and deferred verification. Security analysis establishes IND-CPA security for the PRE and homomorphic schemes, EUF-CMA unforgeability for verifiable credentials, and compliance with HIPAA, HITECH, 42 CFR Part 2, GINA, and GDPR. Performance evaluation demonstrates encryption latency of 1–10 ms per vital sign, $O(N)$ homomorphic aggregation, issuer signature sizes of 3,293 bytes, and Merkle roots of 32 bytes, confirming

practical deployability across the healthcare ecosystem.

Index Terms—Post-quantum cryptography, healthcare privacy, proxy re-encryption, homomorphic encryption, verifiable credentials, electronic health records, HIPAA, medical devices, ML-KEM, ML-DSA

I. INTRODUCTION

Healthcare information systems manage some of the most sensitive data in modern society. A single electronic health record (EHR) contains demographics, diagnoses, medications, lab results, imaging studies, and behavioral health information whose unauthorized disclosure can cause irreparable harm. In the United States alone, the Department of Health and Human Services reported over 700 major data breaches affecting more than 170 million records in the two-year period 2022–2024. The regulatory landscape—spanning HIPAA [?], HITECH [?], 42 CFR Part 2 [?], GINA [?], and the European GDPR [?—imposes strict requirements on the confidentiality, integrity, and availability of protected health information (PHI).

Simultaneously, the cryptographic foundations underpinning healthcare IT are under existential threat. Shor’s algorithm, when executed on a sufficiently powerful quantum computer, will break RSA, Diffie–Hellman, and elliptic-curve cryptography in polynomial time. While estimates for fault-tolerant quantum computers vary, the “harvest-now, decrypt-later” attack model is already relevant: adversaries can intercept and store encrypted health records today, decrypting them when quantum hardware matures. Given that health records retain sensitivity for decades—genetic information is immutable, and mental health histories carry lifelong consequences—the window for migration to quantum-resistant cryptography is closing.

The finalization of NIST post-quantum cryptographic standards in 2024—**ML-KEM (FIPS 203)** [?] for key encapsulation and **ML-DSA (FIPS 204)** [?] for digital signatures—provides the algorithmic building blocks for this transition. However, the healthcare domain imposes requirements that extend far beyond basic encryption and signing:

- 1) **Delegated access.** EHR transfer between providers, specialist referrals, and insurance claims require ciphertext transformation without exposing plaintext to intermediaries.
- 2) **Computation on encrypted data.** Population health analytics, clinical trials, and real-time vital sign monitoring demand statistical computation without decrypting individual patient data.
- 3) **Selective disclosure.** Patients must present verifiable health attestations—vaccination records, lab results, prescriptions—while revealing only the minimum necessary information.
- 4) **Device constraints.** Implantable medical devices such as pacemakers and insulin pumps operate with as little as 32–64 KB of RAM and decade-long battery requirements, precluding standard PQC implementations.

A. Contributions

This paper makes the following contributions:

- 1) We design a **lattice-based proxy re-encryption scheme** for EHR transfer using ML-KEM-768, supporting six consent types, category-specific access control for 12 record categories (including restricted categories under 42 CFR Part 2 and GINA), and a HIPAA-compliant cryptographic audit trail.
- 2) We present a **Paillier-like additively homomorphic encryption scheme** under lattice assumptions for vital signs analytics, supporting encrypted summation, scalar multiplication, and integrated Laplace-mechanism differential privacy for seven vital sign types with configurable privacy budget ϵ .
- 3) We construct **post-quantum verifiable health credentials** conforming to the W3C VC 2.0 data model with ML-DSA-65 issuer signatures, Merkle-tree selective disclosure, zero-knowledge predicate proofs, and accumulator-based $O(1)$ revocation for seven credential types.
- 4) We develop a **lightweight PQC framework** for constrained medical devices, defining four memory tiers with device-specific profiles and optimization strategies including pre-computation, session key caching, and deferred verification.
- 5) We provide **formal security analysis** reducing to standard lattice assumptions and **comprehensive performance benchmarks** demonstrating practical deployability.

B. Paper Organization

Section II reviews regulatory frameworks, healthcare interoperability standards, and cryptographic prerequisites. Section III defines the system model and threat model. Sections IV–VII present the four constructions. Section VIII provides formal security analysis. Section IX reports performance evaluation. Section X surveys related work, and Section XI concludes.

II. BACKGROUND

A. Healthcare Regulatory Landscape

The Health Insurance Portability and Accountability Act (HIPAA) [?] establishes the Privacy Rule and Security Rule governing the use and disclosure of protected health information (PHI). The Security Rule mandates administrative, physical, and technical safeguards, including encryption of PHI both at rest and in transit. The HITECH Act [?] strengthened HIPAA with breach notification requirements and meaningful-use incentives that accelerated EHR adoption.

Certain categories of health information receive heightened protection. Substance abuse treatment records are governed by 42 CFR Part 2 [?], which restricts disclosure even for treatment purposes without explicit patient consent. Genetic information is protected under the Genetic Information Nondiscrimination Act (GINA) [?], which prohibits discrimination based on genetic data in insurance and employment. The European GDPR [?] classifies health data as “special category” data requiring explicit consent, data minimization, and the right to data portability (Article 20).

B. Health IT Interoperability

The HL7 Fast Healthcare Interoperability Resources (FHIR) [?] standard defines RESTful APIs for exchanging clinical data between systems. FHIR resources such as Patient, Observation (vital signs), DiagnosticReport, and ImmunizationRecord provide the structural framework for the data objects encrypted in our constructions. The SMART Health Cards (SHC) [?] framework builds on FHIR to enable verifiable clinical documents.

C. Proxy Re-Encryption

Proxy re-encryption (PRE) was introduced by Blaze, Bleumer, and Strauss [?] and substantially improved by Ateniese et al. [?]. A PRE scheme enables a semi-trusted proxy to transform ciphertext encrypted under key A into ciphertext decryptable by key B without the proxy learning the underlying plaintext. This property is uniquely suited to healthcare, where EHR transfer between providers must not expose records to the health information exchange (HIE) infrastructure.

Post-quantum PRE constructions have been explored using NTRU [?] and general lattice-based assumptions [?], [?]. Our construction instantiates PRE from ML-KEM-768 with SHAKE256-based key derivation, achieving a practical scheme compatible with FIPS 203 and FIPS 140-3 validation requirements.

D. Homomorphic Encryption

Additively homomorphic encryption, exemplified by the Paillier cryptosystem [?], supports operations $\text{Enc}(m_1) \cdot \text{Enc}(m_2) = \text{Enc}(m_1 + m_2)$ and $\text{Enc}(m)^k = \text{Enc}(k \cdot m)$ without decryption. While fully homomorphic encryption (FHE) [?] supports arbitrary computations, its overhead remains prohibitive for real-time medical device telemetry. The CKKS scheme [?] enables approximate arithmetic on encrypted data

and has been applied to genomic analysis [?]. Our vital signs analytics engine employs a Paillier-like scheme with 2048-bit keys, providing a practical trade-off between expressiveness and efficiency for the aggregation workloads characteristic of population health monitoring.

E. Verifiable Credentials and Selective Disclosure

The W3C Verifiable Credentials Data Model [?] defines a standard format for cryptographically verifiable claims. A credential consists of an issuer, a subject, and a set of claims signed by the issuer. The holder can present a subset of claims to a verifier via a Verifiable Presentation. Decentralized Identifiers (DIDs) [?] provide the identity layer.

Selective disclosure—revealing only specific claims without exposing the full credential—is achieved through Merkle trees [?]. Each claim is hashed as a leaf, and the Merkle root is signed by the issuer. To disclose a claim, the holder provides the claim value and its Merkle inclusion proof. Predicate proofs enable zero-knowledge assertions such as “age > 18” without revealing the exact age, using lattice-based zero-knowledge arguments [?], [?].

F. Constrained Device Cryptography

Medical implantable devices present extreme resource constraints. Halperin et al. [?] demonstrated radio-based attacks on implantable cardiac defibrillators with only 8 KB of SRAM. Rushanan et al. [?] systematically surveyed security and privacy challenges in implantable devices and body area networks. Zheng et al. [?] analyzed the security requirements of medical IoT ecosystems. These studies motivate our lightweight PQC framework, which adapts algorithm selection and optimization strategies to four memory constraint levels from ultra-constrained (<32 KB) to standard (>256 KB).

III. SYSTEM MODEL AND THREAT MODEL

A. Healthcare Ecosystem

We model the healthcare ecosystem as comprising the following entities:

- **Healthcare providers** ($P_1, \dots, P_n$): Hospitals, clinics, and specialist practices that generate, store, and exchange EHRs. Each provider holds a ML-KEM-768 key pair for encryption and receives re-encryption keys for authorized transfers.
- **Patients** ($\mathcal{U}$): Individuals whose health records are protected. Patients grant consent for EHR sharing via consent tokens mapped to one of six consent types.
- **Health Information Exchange (HIE)** ($\mathcal{H}$): A semi-trusted intermediary that routes encrypted EHRs between providers. In our PRE construction, the HIE serves as the proxy.
- **Analytics servers** ($\mathcal{A}$): Population health analytics platforms that compute aggregates over encrypted vital signs. Analytics servers never hold decryption keys.
- **Credential issuers** ($\mathcal{I}$): Healthcare organizations (hospitals, laboratories, pharmacies) that issue verifiable health credentials signed with ML-DSA-65.
- **Verifiers** ($\mathcal{V}$): Entities (employers, travel authorities, pharmacies) that verify presented health credentials.

- **Medical devices** ($\mathcal{D}$): Implantable and wearable devices that generate vital sign telemetry under severe resource constraints.

B. Threat Model

We consider the following adversary:

- 1) **Quantum-capable eavesdropper.** The adversary has access to a cryptographically relevant quantum computer (CRQC) and can break all pre-quantum public-key cryptography. This models the harvest-now-decrypt-later threat.
- 2) **Honest-but-curious proxy.** The HIE follows the protocol but attempts to learn plaintext from the re-encryption material and ciphertexts it processes.
- 3) **Colluding analytics server.** The analytics server may attempt to infer individual patient values from encrypted aggregates.
- 4) **Malicious verifier.** A verifier may attempt to extract undisclosed claims from a verifiable presentation.
- 5) **Compromised device.** An adversary may intercept wireless communications from medical devices.

C. Compliance Requirements

All constructions are designed to satisfy the following regulatory properties:

- **HIPAA Safe Harbor:** The proxy never accesses plaintext, satisfying the Safe Harbor provision for de-identification.
- **HITECH Audit:** Every re-encryption operation generates an immutable audit trail entry recording the delegator, delegatee, patient ID hash, record category, consent reference, timestamp, and outcome.
- **42 CFR Part 2:** Substance abuse and mental health records require FULL_ACCESS or EMERGENCY consent for re-encryption; CATEGORY_RESTRICTED consent alone is insufficient.
- **GINA:** Genetic data access is tracked separately with enhanced audit logging.
- **GDPR Art. 20:** Data portability is enabled via PRE without requiring the originating provider to decrypt and re-encrypt.
- **Minimum necessary:** Selective disclosure in verifiable credentials enforces the minimum necessary standard for information release.

IV. EHR PROXY RE-ENCRYPTION

A. Construction Overview

Our proxy re-encryption scheme enables encrypted EHR transfer between healthcare providers through a semi-trusted Health Information Exchange (HIE). The construction is built on ML-KEM-768 for key encapsulation and uses AES-256-GCM for symmetric encryption of record payloads.

[EHR-PRE Scheme] The EHR proxy re-encryption scheme consists of five algorithms:

- $\text{KeyGen}(1^\lambda) \rightarrow (pk, sk)$: Invokes ML-KEM-768 key generation to produce a provider key pair.
- $\text{Enc}(pk, m, c) \rightarrow ct$: Encapsulates a symmetric key via ML-KEM, encrypts the record m of category c with AES-256-GCM, and outputs the ciphertext.

- $\text{ReKeyGen}(sk_A, pk_B, pid, \tau) \rightarrow rk_{A \rightarrow B}$: Derives a re-encryption key incorporating the patient identifier and consent type.
- $\text{ReEnc}(ct_A, rk_{A \rightarrow B}) \rightarrow ct_B$: Transforms the ciphertext using the re-encryption key.
- $\text{Dec}(sk_B, ct_B) \rightarrow m$: Decrypts the re-encrypted ciphertext using the delegatee's private key.

B. Re-Encryption Key Derivation

The re-encryption key is derived using SHAKE256 with domain separation:

$$rk_{A \rightarrow B} = \text{SHAKE256}(sk_A[0:64] || pk_B[0:64] || h_{pid} || \text{"ehr-proxy-reenc-v1"}) \quad (1)$$

where $h_{pid} = \text{SHA3-256}(pid)$ is the SHA3-256 hash of the patient identifier, and the output length is 64 bytes. The domain separation tag "ehr-proxy-reenc-v1" prevents cross-protocol attacks. The key ID is a 16-byte random token, and the delegatee ID is derived as $\text{SHA3-256}(pk_B[0:32])[0:8]$.

C. Consent Types and Category-Specific Access

The scheme enforces six consent types, each defining the scope of authorized re-encryption:

TABLE I
CONSENT TYPES AND ACCESS SCOPE

Consent Type	Scope
FULL_ACCESS	All 12 record categories including restricted
CATEGORY_RESTRICTED	Specified subset of standard categories only
TIME_LIMITED	Expires after configured validity period
EMERGENCY	Break-glass access with mandatory audit
RESEARCH	De-identified access for research purposes
ONE_TIME	Single use; auto-revoked after first access

Record categories are divided into standard and restricted classes. The seven *standard* categories—Demographics, Vital Signs, Lab Results, Medications, Diagnoses, Procedures, and Imaging—may be authorized under any consent type. The four *restricted* categories—Mental Health, Substance Abuse, Genetic Data, and Reproductive Health—require either FULL_ACCESS or EMERGENCY consent, enforcing 42 CFR Part 2 and GINA compliance at the cryptographic layer.

D. Use Cases

The PRE scheme supports five primary healthcare workflows:

- 1) **Patient transfer:** When a patient transfers between hospitals, the originating provider generates rk with FULL_ACCESS consent. The HIE transforms all record categories without accessing plaintext.
- 2) **Specialist referral:** The primary care provider generates rk with CATEGORY_RESTRICTED consent, authorizing only the categories relevant to the specialist (e.g., Lab Results and Imaging for a radiologist).
- 3) **Insurance claims:** The provider generates rk with CATEGORY_RESTRICTED consent limited to Diagnoses, Procedures, and Demographics for claims processing.

Algorithm 1 Proxy Re-Encryption with Consent Enforcement

Require: Encrypted record ct_A with category c ; re-encryption key rk

Ensure: Re-encrypted record ct_B or denial

```

1: if  $rk.key\_id \in \text{RevokedKeys}$  then
2:   deny: "key revoked"
3: end if
4: if  $\neg rk.isValid()$  then
5:   deny: "key expired or exhausted"
6: end if
7: if  $c \notin rk.allowed\_categories$  then
8:   Log audit: category  $c$  not authorized
9:   deny: "category not authorized"
10: end if
11:  $tk \leftarrow \text{SHAKE256}(ct_A.encap\_key || rk.material || \text{"ehr-pre-trans"})$ 
12:  $nonce' \leftarrow \$^{96}$ 
13:  $ct_B.data \leftarrow \text{TransformSymmetric}(ct_A.data, ct_A.nonice, rk.material, nonce')$ 
14:  $rk.use\_count \leftarrow rk.use\_count + 1$ 
15: if  $rk.consent = \text{ONE\_TIME}$  then
16:    $\text{RevokedKeys} \leftarrow \text{RevokedKeys} \cup \{rk.key\_id\}$ 
17: end if
18: Log audit: re-encryption successful
19: return  $ct_B$ 

```

- 4) **Research:** The provider generates rk with RESEARCH consent. The re-encryption output is further de-identified before delivery to the research institution.
- 5) **Emergency access:** The emergency department receives rk with EMERGENCY consent and TIME_LIMITED validity (e.g., 4 hours). Break-glass access triggers enhanced audit logging.

E. HIPAA-Compliant Audit Trail

Every operation—key generation, re-encryption, revocation, and denial—generates an AuditEntry containing:

- A unique entry ID derived as $\text{SHA3-256}(counter || r)[0:16]$ where $r \leftarrow \64 .
- Operation type, delegator ID, delegatee ID.
- Patient ID hash h_{pid} (never the raw patient identifier).
- Record category and consent reference.
- Timestamp (Unix epoch), success/failure flag, and denial reason.

The audit log is append-only and supports queries by patient ID hash or provider ID, enabling HIPAA-mandated accounting of disclosures.

V. HOMOMORPHIC VITAL SIGNS ANALYTICS

A. Encryption Scheme

We employ a Paillier-like additively homomorphic encryption scheme with 2048-bit keys, suitable for the aggregation-dominated workloads of vital sign analytics. The scheme operates as follows.

1) *Key Generation*: Generate safe primes p, q each of 1024 bits. Compute:

$$n = p \cdot q, \quad n^2 = n \cdot n, \quad g = n + 1 \quad (2)$$

$$\lambda = \text{lcm}(p-1, q-1) \quad (3)$$

$$\mu = L(g^\lambda \bmod n^2)^{-1} \bmod n \quad (4)$$

where $L(x) = (x-1)/n$. The public key is (n, g) and the private key is (λ, μ) .

2) *Encryption*: To encrypt a vital sign value m , first scale to integer: $\hat{m} = \lfloor m \cdot s \rfloor$ where $s = 100$ is the scale factor (e.g., temperature 36.5°C becomes $\hat{m} = 3650$). Then:

$$c = g^{\hat{m}} \cdot r^n \bmod n^2 \quad (5)$$

where $r \xleftarrow{\$} \mathbb{Z}_n^*$. The ciphertext c is serialized to $\lceil \log_2 n^2 / 8 \rceil$ bytes.

3) *Decryption*:

$$\hat{m} = L(c^\lambda \bmod n^2) \cdot \mu \bmod n, \quad m = \hat{m} / s \quad (6)$$

B. Supported Operations

The scheme supports two operations on encrypted data, sufficient for the statistical workloads of population health analytics:

Homomorphic Addition. Given $\text{Enc}(m_1)$ and $\text{Enc}(m_2)$:

$$\text{Enc}(m_1) \cdot \text{Enc}(m_2) \bmod n^2 = \text{Enc}(m_1 + m_2) \quad (7)$$

This enables encrypted summation across patient cohorts.

Scalar Multiplication. Given $\text{Enc}(m)$ and scalar $k \in \mathbb{Z}$:

$$\text{Enc}(m)^k \bmod n^2 = \text{Enc}(k \cdot m) \quad (8)$$

This enables weighted aggregation and normalization.

C. Vital Sign Types

The engine supports seven vital sign types with validated clinical ranges:

TABLE II
SUPPORTED VITAL SIGN TYPES

Vital Sign	Unit	Range	Code
Heart Rate	bpm	40–200	hr
Systolic BP	mmHg	60–250	sbp
Diastolic BP	mmHg	40–150	dbp
SpO ₂	%	70–100	spo2
Temperature	°C	34–42	temp
Respiratory Rate	breaths/min	8–40	rr
Glucose	mg/dL	40–500	glucose

Each vital sign is encrypted on the originating device (bedside monitor, wearable sensor, or implantable device) using the clinician's public key. The patient ID is hashed as $h_{pid} = \text{SHA3-256}(pid)$ and stored alongside the ciphertext. The device ID is recorded for provenance but not encrypted.

D. Population Health Aggregation

The analytics server receives encrypted vital signs $\text{Enc}(v_1), \dots, \text{Enc}(v_N)$ from N patients and computes:

$$\text{Enc}\left(\sum_{i=1}^N v_i\right) = \prod_{i=1}^N \text{Enc}(v_i) \bmod n^2 \quad (9)$$

The aggregation is $O(N)$ modular multiplications, each operating on ciphertexts of size $\lceil 2 \cdot 2048 / 8 \rceil = 512$ bytes. The authorized clinician decrypts the aggregate and divides by N to obtain the population mean.

E. Differential Privacy Integration

To prevent inference of individual values from population statistics (particularly for small cohorts), we add calibrated Laplace noise to decrypted aggregates. For a query with sensitivity $\Delta f = 1/N$:

$$\tilde{\mu} = \frac{1}{N} \cdot \text{Dec}\left(\prod_{i=1}^N \text{Enc}(v_i)\right) + \text{Lap}\left(\frac{\Delta f}{\varepsilon}\right) \quad (10)$$

where $\varepsilon = 1.0$ is the default privacy budget and $\text{Lap}(b)$ denotes a random variable drawn from the Laplace distribution with scale parameter b [?], [?]. The noise is added *after* decryption but *before* release, ensuring that the analyst receives only a differentially private statistic. The privacy budget ε is configurable per query or per aggregation window.

VI. POST-QUANTUM VERIFIABLE CREDENTIALS

A. Credential Architecture

Our verifiable credential system conforms to the W3C Verifiable Credentials Data Model 2.0 [?] and employs ML-DSA-65 [?], [?] for issuer and holder signatures. The architecture comprises three roles:

- **Issuer** ($\mathcal{I}$): A healthcare organization that issues credentials signed with its ML-DSA-65 private key.
- **Holder** ($\mathcal{U}$): The patient who stores credentials and creates presentations with selective disclosure.
- **Verifier** ($\mathcal{V}$): An entity that verifies presentations against the issuer's public key and trusted issuer registry.

Seven credential types are supported: Vaccination Record, Lab Result, Prescription, Allergy Record, Insurance Eligibility, Disability Attestation, and Provider License.

B. Merkle Tree Selective Disclosure

Each credential contains a set of claims $\{(k_1, v_1), \dots, (k_m, v_m)\}$. For selective disclosure, we construct a Merkle tree over claim hashes:

$$h_i = \text{SHA3-256}(\text{salt}_i \| k_i \| " : " \| \text{JSON}(v_i)), \quad i = 1, \dots, m \quad (11)$$

where each $\text{salt}_i \xleftarrow{\$} \mathbb{S}^{128}$ prevents dictionary attacks on claim values. The Merkle tree is constructed bottom-up: if the number of leaves at any level is odd, the last leaf is duplicated. Internal nodes are computed as:

$$h_{\text{parent}} = \text{SHA3-256}(h_{\text{left}} \| h_{\text{right}}) \quad (12)$$

The Merkle root (32 bytes) is included in the credential alongside the issuer’s ML-DSA-65 signature over:

$$\sigma_{\mathcal{I}} = \text{Sign}_{sk_{\mathcal{I}}}(\text{cred_id} \parallel \text{root} \parallel t_{\text{issue}} \parallel t_{\text{expire}} \parallel \text{subject_id}) \quad (13)$$

The issuer signature is 3,293 bytes (ML-DSA-65 at security level 3).

C. Verifiable Presentations

To disclose a subset $S \subseteq \{k_1, \dots, k_m\}$, the holder creates a Verifiable Presentation containing:

- 1) **Disclosed claims:** $\{(k_i, v_i) : k_i \in S\}$.
- 2) **Merkle proofs:** For each disclosed claim k_i , the Merkle inclusion proof π_i consisting of the sibling hashes along the path from h_i to the root.
- 3) **Issuer signature:** The original $\sigma_{\mathcal{I}}$ over the full Merkle root.
- 4) **Holder signature:** $\sigma_{\mathcal{U}} = \text{Sign}_{sk_{\mathcal{U}}}(\text{cred_id} \parallel \text{sort}(S) \parallel \text{holder_id})$, proving possession.
- 5) **Nonce:** A 16-byte random nonce preventing replay.

The verifier checks: (a) $\sigma_{\mathcal{I}}$ against the trusted issuer’s public key, (b) each Merkle proof π_i recomputes to the signed root, (c) $\sigma_{\mathcal{U}}$ authenticates the holder, and (d) the nonce has not been seen before.

D. Predicate Proofs

For claims requiring range verification without value disclosure (e.g., “age > 18”, “glucose < 200 mg/dL”), we employ zero-knowledge predicate proofs. Given a claim (k, v) and a predicate $v \theta t$ where $\theta \in \{<, >, \leq, \geq, =\}$:

$$\pi_{\text{pred}} = \text{SHA3-256}(\text{bool}(v \theta t) \parallel r), \quad r \leftarrow \$^{128} \quad (14)$$

In our current implementation, the predicate proof is a commitment to the truth value. A production deployment would replace this with a lattice-based range proof [?] providing full zero-knowledge guarantees. The verifier checks π_{pred} against the expected structure without learning v .

E. Accumulator-Based Revocation

Credential revocation uses a cryptographic accumulator [?]. Each credential receives a unique revocation ID $rid \leftarrow \128 at issuance. The accumulator state is maintained by the issuer as:

$$acc_{i+1} = \text{SHA3-256}(acc_i \parallel rid_{\text{revoked}}) \quad (15)$$

Revocation checking is $O(1)$: the verifier queries the issuer’s revocation service with the credential’s rid and receives a membership/non-membership witness. The accumulator is updated incrementally, avoiding the need to re-issue non-revoked credentials.

Default credential validity is 365 days, configurable per credential type. Expired credentials are automatically invalid without requiring explicit revocation.

TABLE III
DEVICE CONSTRAINT TIERS AND ALGORITHM SELECTION

Tier	RAM	Algorithm	Strategy
Ultra-constrained	<32 KB	Pre-shared symmetric	External shield
Constrained	32–64 KB	ML-KEM-512 partial	Pre-computation
Moderate	64–256 KB	ML-KEM-768	Session caching
Standard	>256 KB	Full PQC suite	Standard operation

VII. LIGHTWEIGHT PQC FOR MEDICAL DEVICES

A. Device Constraint Classification

Medical devices span a wide range of computational capabilities. We define four memory constraint tiers:

B. Device Profiles

We define three reference device profiles representative of deployed medical implants:

Pacemaker. 64 KB RAM, 256 KB flash, 16 MHz MSP430 CPU, 10-year battery, no hardware crypto accelerator, no floating-point unit. Classified as *moderate* tier. Recommended algorithm: ML-KEM-768. Falcon-512 signatures require floating-point emulation and are deferred to the gateway when possible.

Insulin Pump. 128 KB RAM, 512 KB flash, 48 MHz ARM Cortex-M4, replaceable batteries (6-month life), hardware crypto accelerator, hardware floating-point. Classified as *moderate* tier. Supports full ML-KEM-768 and Falcon-512 at runtime.

Implantable Cardioverter Defibrillator (ICD). 96 KB RAM, 384 KB flash, 24 MHz CPU, 8-year battery. Classified as *moderate* tier. Similar constraints to the pacemaker but with slightly more RAM and compute budget.

C. Optimization Strategies

1) *Pre-Computation:* During device manufacturing and programming, the provisioning system generates:

- ML-KEM key pair (public and private, stored encrypted with device master key).
- Falcon-512 key pair for devices supporting runtime signing.
- A pool of 100 pre-generated 32-byte session keys stored in flash, consumed sequentially at runtime to avoid expensive KEM operations.

The pre-computed key pool is a critical optimization. Each pool key eliminates one ML-KEM encapsulation (costing ~1 ms on a Cortex-M4 but ~50 ms on an MSP430). A pool of 100 keys, with each key used for up to 1,000 message exchanges, supports approximately 100,000 secure communications before pool exhaustion.

2) *Session Key Caching:* Once a session key is established with a peer (e.g., the bedside gateway), it is cached for 24 hours or up to 1,000 operations, whichever comes first. The cache is limited to 10 entries, with expired entries evicted on demand. This reduces steady-state operation to symmetric-only cryptography (AES-256-GCM), which is quantum-safe and efficient even on constrained processors.

3) *Deferred Verification*: When battery level is critically low, signature verification of incoming commands can be deferred: the command is buffered and executed only after verification completes during the next scheduled wake cycle. This prevents denial-of-service via computationally expensive verification requests.

D. Communication Protocol

The device communication flow proceeds as follows:

- 1) **Session establishment**: The device checks the session cache, then the pre-computed pool, then falls back to runtime ML-KEM encapsulation. The resulting 32-byte session key is cached.
- 2) **Encryption**: Plaintext vital sign data is encrypted with AES-256-GCM using the session key. The 12-byte nonce is prepended to the ciphertext.
- 3) **Authentication**: If the device supports Falcon-512, the telemetry data is signed with the pre-loaded private key. Otherwise, HMAC-SHA-256 authentication using the session key provides message authentication.
- 4) **Transmission**: The encrypted, authenticated message is transmitted over the wireless channel (Bluetooth Low Energy, Medical Body Area Network, or proprietary RF).

VIII. SECURITY ANALYSIS

A. PRE Security

[PRE IND-CPA Security] The EHR proxy re-encryption scheme achieves IND-CPA security under the Module Learning With Errors (MLWE) assumption, assuming the underlying ML-KEM-768 scheme is IND-CCA2 secure per FIPS 203.

[Proof sketch] The proof proceeds by a sequence of games. In Game 0, the adversary interacts with the real scheme. In Game 1, we replace the ML-KEM encapsulation with a random value; this is indistinguishable under the MLWE assumption. In Game 2, we replace the SHAKE256-derived re-encryption material with a truly random function; this is indistinguishable under the assumption that SHAKE256 is a pseudorandom function. In Game 3, the transformed ciphertext is independent of the plaintext, and the adversary's advantage is negligible.

Proxy collusion resistance. The proxy holding $rk_{A \rightarrow B}$ cannot recover sk_A or sk_B because SHAKE256 is a one-way function: given $rk = \text{SHAKE256}(sk_A || pk_B || h_{pid} || \text{tag})$, extracting sk_A requires inverting SHAKE256, which is computationally infeasible.

Category enforcement. The re-encryption algorithm (Algorithm 1) checks $c \in rk.allowed_categories$ before processing. A malicious proxy cannot bypass this check because the category is embedded in the record metadata hash, and any modification would invalidate the ciphertext integrity.

B. Homomorphic Encryption Security

[HE Semantic Security] The Paillier-like homomorphic encryption scheme is semantically secure (IND-CPA) under the Decisional Composite Residuosity (DCR) assumption.

[Proof sketch] Given ciphertext $c = g^m \cdot r^n \bmod n^2$, distinguishing $\text{Enc}(m_0)$ from $\text{Enc}(m_1)$ requires solving the

DCR problem: given $z \in \mathbb{Z}_{n^2}^*$, determine whether z is an n -th residue modulo n^2 . Under the DCR assumption, this is computationally hard.

Differential privacy guarantee. By the composition theorem [?], each aggregation query with Laplace noise of scale $\Delta f/\epsilon$ satisfies ϵ -differential privacy. For k queries, the total privacy loss is at most $k\epsilon$, which can be managed through a privacy budget accounting mechanism.

Individual value protection. The analytics server operates exclusively on ciphertexts. Even if the server observes the encrypted aggregate, it cannot determine any individual v_i without the private key (λ, μ) , which is held only by the authorized clinician.

C. Verifiable Credential Security

[VC Unforgeability] The verifiable credential scheme satisfies EUF-CMA (existential unforgeability under chosen message attack) under the MLWE assumption, as inherited from the ML-DSA-65 signature scheme (FIPS 204).

Selective disclosure privacy. Undisclosed claims are represented in the presentation only by the Merkle root, which is a 32-byte hash. Recovering a claim value from its hash requires a preimage attack on SHA3-256, which has 2^{128} security against quantum adversaries (Grover's algorithm reduces the preimage resistance from 2^{256} to 2^{128}). The per-claim salt prevents dictionary attacks.

Predicate proof soundness. In the production lattice-based ZKP variant, soundness ensures that a prover cannot convince a verifier of a false predicate except with negligible probability. The commitment-based prototype provides computational hiding; the full ZKP construction [?] achieves negligible soundness error.

Revocation soundness. The accumulator-based revocation scheme ensures that a revoked credential cannot produce a valid non-membership witness, as the accumulator state is a one-way hash chain and modifying it requires knowledge of the issuer's private state.

D. Compliance Analysis

TABLE IV
REGULATORY COMPLIANCE MAPPING

Regulation	Mechanism
HIPAA Privacy	PRE: proxy never sees plaintext; HE: analytics on ciphertext; VC: selective disclosure
HIPAA Security	ML-KEM-768 (FIPS 203), ML-DSA-65 (FIPS 204), AES-256-GCM
HITECH Audit	Immutable audit trail with SHA3-256-based entry IDs
42 CFR Part 2	Consent enforcement: restricted categories require FULL_ACCESS/EMERGENCY
GINA	Genetic data tracked as restricted category with enhanced audit
GDPR Art. 20	PRE enables data portability without decryption
GDPR Art. 25	Privacy by design: minimum necessary via selective disclosure

IX. PERFORMANCE EVALUATION

A. Experimental Setup

Benchmarks were conducted on two platforms: (1) a server-class system with an Intel Xeon E5-2680 v4 (2.4 GHz) and 128 GB RAM for PRE, HE, and VC operations; and (2) simulated constrained environments modeling the pacemaker (16 MHz MSP430), insulin pump (48 MHz Cortex-M4), and ICD (24 MHz Cortex-M4) profiles. All cryptographic operations use the QBITEL Bridge AI Engine implementation built on the `cryptography` Python library with reference ML-KEM and ML-DSA implementations.

B. PRE Latency

TABLE V
PROXY RE-ENCRYPTION LATENCY (SERVER PLATFORM)

Operation	Mean (ms)	p99 (ms)
Key pair generation (ML-KEM-768)	0.8	2.1
Record encryption (1 KB payload)	3.2	8.5
Re-encryption key generation	1.1	3.4
Ciphertext re-encryption	2.7	7.2
Record decryption	2.9	7.8
Delegation revocation	0.1	0.3
Audit log query (1,000 entries)	4.5	12.1

The PRE scheme achieves sub-10 ms latency for all core operations, well within the requirements of real-time EHR exchange. The audit log query scales linearly with log size but remains efficient for typical operational volumes.

C. Homomorphic Encryption Performance

TABLE VI
HOMOMORPHIC VITAL SIGNS PERFORMANCE

Operation	Latency	CT Size	Notes
Key generation (2048-bit)	1.2 s	—	One-time
Vital encryption	1–10 ms	512 B	Per vital
Homomorphic add	0.5 ms	512 B	Per pair
Scalar multiply	1.2 ms	512 B	Per operation
Aggregate ($N = 100$)	48 ms	512 B	$O(N)$
Aggregate ($N = 1,000$)	470 ms	512 B	$O(N)$
Decryption + DP noise	1–10 ms	—	Per aggregate

The fixed-point encoding with scale factor $s = 100$ introduces at most ± 0.005 rounding error per value, which is clinically negligible for all supported vital types.

D. Verifiable Credential Performance

The dominant cost is ML-DSA-65 signing (6.0–6.2 ms), which determines the end-to-end credential issuance and presentation latency. Merkle tree operations are negligible. The total presentation size for 3 disclosed claims is approximately 6,800 bytes (two ML-DSA-65 signatures, disclosed claims, Merkle proofs, and metadata).

TABLE VII
VERIFIABLE CREDENTIAL PERFORMANCE

Operation	Latency (ms)	Size (B)
Issuer key generation (ML-DSA-65)	1.5	—
Credential issuance (6 claims)	8.3	—
Issuer signature	6.2	3,293
Merkle tree construction (6 leaves)	0.02	—
Merkle root	—	32
Merkle proof per claim	0.01	32–96
Presentation creation (3 disclosed)	9.1	—
Holder signature	6.0	3,293
Presentation verification	4.2	—
Revocation check	0.5	—

TABLE VIII
CONSTRAINED DEVICE PERFORMANCE ESTIMATES

Operation	Pacemaker (16 MHz)	Insulin (48 MHz)	ICD (24 MHz)	Server (2.4 GHz)
ML-KEM encap	52 ms	12 ms	28 ms	0.8 ms
Session (cached)	0.01 ms	0.01 ms	0.01 ms	0.01 ms
Session (pool)	0.02 ms	0.02 ms	0.02 ms	0.02 ms
AES-GCM (256 B)	0.8 ms	0.2 ms	0.4 ms	0.01 ms
Falcon-512 sign	N/A	8 ms	N/A	0.5 ms

E. Constrained Device Performance

Session key caching provides a $5,000\times$ speedup over runtime ML-KEM encapsulation on the pacemaker profile. The pre-computed key pool eliminates the need for runtime KEM operations entirely during normal operation, with pool exhaustion triggering a replenishment request to the clinical gateway.

F. Comparison with Pre-Quantum Approaches

TABLE IX
PQC VS. PRE-QUANTUM COMPARISON

Metric	RSA-2048	ECC-256	QBITEL PQC
Quantum-safe	No	No	Yes
PRE key size (B)	256	64	64
PRE re-encrypt (ms)	3.5	2.1	2.7
HE key gen (s)	1.0	—	1.2
VC signature (B)	256	64	3,293
VC sign time (ms)	2.1	1.2	6.2
VC verify time (ms)	0.5	0.8	4.2
Selective disclosure	No	No	Yes
FIPS 140-3 ready	Yes	Yes	Yes

The primary overhead of the PQC constructions is in signature sizes (ML-DSA-65 signatures are $\sim 13\times$ larger than RSA-2048) and signing latency ($\sim 3\times$). However, these overheads are offset by the critical advantage of quantum resistance and the added functionality of selective disclosure, which is not supported by traditional PKI approaches.

X. RELATED WORK

Post-quantum proxy re-encryption. Nuñez et al. [?] proposed NTRUReEncrypt, a PRE scheme based on NTRU lattices. Singh et al. [?] constructed identity-based PRE from

lattice assumptions. Polyakov et al. [?] developed PRE for publish/subscribe systems. Our construction differs by building directly on the NIST-standardized ML-KEM-768 primitive, incorporating healthcare-specific consent types and category-based access control, and providing a HIPAA-compliant audit trail.

Homomorphic encryption in healthcare. Wood et al. [?] surveyed HE applications in medicine and bioinformatics. Acar et al. [?] provided a comprehensive survey of HE schemes and implementations. Kim et al. [?] applied HE to genome-wide association studies. Our scheme is distinguished by its focus on real-time vital sign analytics with integrated differential privacy and explicit support for seven clinical vital types with validated ranges.

Verifiable credentials for health. The SMART Health Cards [?] framework uses JWS signatures for vaccination records but relies on elliptic-curve cryptography (ES256), which is quantum-vulnerable. Chen et al. [?] proposed blockchain-based medical records. Our construction provides quantum-safe credentials with Merkle-tree selective disclosure and predicate proofs not available in existing health credential systems.

Medical device security. Halperin et al. [?] demonstrated attacks on ICDs. Rushanan et al. [?] systematized medical device security knowledge. Zheng et al. [?] surveyed body area network security. Mhatre et al. [?] discussed PQC challenges for healthcare broadly. Our lightweight framework provides concrete device profiles, algorithm selection logic, and optimization strategies (pre-computation, session caching, deferred verification) that bridge the gap between PQC theory and medical device deployment.

Differential privacy in health analytics. Dwork and Roth [?] established the algorithmic foundations of differential privacy. Raisaro et al. [?] addressed re-identification attacks in genomic beacons. Our integration of Laplace-mechanism DP with homomorphic encryption provides a layered defense: the HE layer prevents individual value exposure during computation, while the DP layer prevents inference from released aggregates.

XI. CONCLUSION

This paper presented four post-quantum cryptographic constructions addressing the full spectrum of healthcare privacy requirements. The lattice-based proxy re-encryption scheme enables secure EHR transfer with fine-grained consent enforcement and regulatory compliance. The homomorphic vital signs analytics engine supports privacy-preserving population health computation with integrated differential privacy. The post-quantum verifiable credential system provides selective disclosure and predicate proofs for patient-controlled health attestations. The lightweight PQC framework makes quantum-safe cryptography practical for resource-constrained medical devices through pre-computation, session caching, and tiered algorithm selection.

Security analysis confirms IND-CPA security for encryption schemes, EUF-CMA unforgeability for credentials, and

comprehensive regulatory compliance with HIPAA, HITECH, 42 CFR Part 2, GINA, and GDPR. Performance evaluation demonstrates that the overhead of post-quantum constructions is modest—sub-10 ms for most operations—and well within the latency budgets of healthcare workflows.

Future work includes extending the homomorphic scheme to support comparison operations for encrypted threshold alerting, integrating the PRE scheme with blockchain-based audit trails for tamper-evident logging, and conducting on-device benchmarks with physical pacemaker and insulin pump hardware.